

ASSET TRACKER PLATFORM

API Reference

Version 1.0 · *OpenAPI 3.1*

Complete REST contract for any integration calling the Asset Tracker platform — authentication, asset lookup, photo upload, maintenance, repairs, recovery, audit verification, and reference data.

April 29, 2026

Confidential — internal use

Contents

1. Overview & conventions
2. Base URLs & environments
3. Authentication
4. Common headers
5. Error envelope & error codes
6. Rate limiting
7. Idempotency
8. Pagination
9. Endpoints — Health
10. Endpoints — Auth
11. Endpoints — Assets
12. Endpoints — Photos
13. Endpoints — Maintenance
14. Endpoints — Repairs
15. Endpoints — Recovery
16. Endpoints — Audit
17. Endpoints — Reference data
18. Schemas
19. Scope catalogue
20. Permitted-actions matrix
21. Asset status enum
22. Versioning policy
23. Changelog & support

1. Overview & conventions

This document is the complete REST contract for the Asset Tracker platform API. The accompanying machine-readable spec is `server/openapi.yaml` (OpenAPI 3.1) — load it into Postman, Insomnia, or generate a typed client with `openapi-generator`. When the spec and this document disagree, the spec wins; it is validated against the running server.

Wire-format conventions

Topic	Convention
Format	JSON, UTF-8
Casing	camelCase on the wire (server translates from snake_case)
Timestamps	ISO 8601 with timezone — e.g. 2026-04-29T11:32:18.412Z
Dates	YYYY-MM-DD
IDs	UUID v4 unless otherwise noted
Money	number (not string). Currency from <code>organization.currency</code>
Booleans	native true / false
Null fields	explicit null — never omitted

2. Base URLs & environments

All endpoints below are prefixed with `/api/v1` unless under `/health` or `/api/v1/admin/*`.

Environment	Base URL
Local development	<code>http://localhost:4000</code>
Staging	(to be assigned)
Production	<code>https://asset.thebizzfly.com</code>

Configure the base URL in your client's environment settings. The web admin UI uses `VITE_MOBILE_API_URL`.

3. Authentication

All requests use the standard **Bearer** scheme:

```
Authorization: Bearer <token>
```

There are two kinds of bearer token; the server tells them apart by their shape, so the same header carries either:

Kind	Format	Issued by	Lifetime
API key	<orgslug>_<live test>_<24chars>	Org admin (web UI)	Indefinite, or expires_at
Access JWT	Standard HS256 JWT	POST /auth/login	30 minutes

Which token to send

Endpoint group	Send
POST /auth/login, /auth/refresh, /auth/logout	API key only
GET /auth/me	User JWT only
All other endpoints	Either — JWT for user-scoped, API key for server-to-server
GET /health	No auth

API key format

The key is composed from your organization's short name, an environment tag (live in production, test elsewhere), and 24 random base-62 chars:

```
1xL_live_K8j3pQrX9bR2sN7wHzVc1qLm
demo_test_K8j3pQrX9bR2sN7wHzVc1qLm
acmecorp_live_K8j3pQrX9bR2sN7wHzVc
```

Keys are bcrypt-hashed server-side. The full secret is shown **only once** on creation — store it in your secrets manager immediately.

Refresh-token rotation

POST /auth/refresh returns a new refresh token **and** revokes the old one. Clients must store the new value immediately. Reusing a revoked refresh token revokes **every** active session for the user — this is the reuse-detection defence against stolen tokens.

4. Common headers

Header	Direction	Purpose
Authorization	Request	Bearer <token> — required (except /health)
X-Request-Id	Request + Response	Optional client id [A-Z a-z 0-9 . _ : -], 1–128 chars. Mirrored on every response and error
Idempotency-Key	Request	Required-ish for POST mutations. See section 7.
X-RateLimit-Limit	Response	Per-key limit (req/min)
X-RateLimit-Remaining	Response	Tokens left in the current window
X-RateLimit-Reset	Response	Unix epoch when the bucket refills
Retry-After	Response (429 only)	Seconds to wait

5. Error envelope & error codes

Every non-2xx response uses this exact shape:

```
{
  "error": {
    "code": "ASSET_NOT_FOUND",
    "message": "Asset not found",
    "requestId": "5b1a4d8c-7c80-4f19-a64a-7b9f3a8b2c11",
    "fieldErrors": [
      { "field": "assetId", "message": "Invalid uuid" }
    ],
    "details": null
  }
}
```

code is the only field clients should branch on — strings are stable across versions. **message** is human-readable and may change wording. **requestId** is also echoed in the X-Request-Id response header. **fieldErrors** is present for `VALIDATION_FAILED` and is suitable for inline form errors.

All error codes

HTTP	code	When
400	INVALID_QR_PAYLOAD	qrPayload didn't parse as UUID, asset tag, or known URL
401	UNAUTHENTICATED	Missing/bad credentials, or wrong-org user
401	TOKEN_EXPIRED	Access JWT has aged out — call <code>/auth/refresh</code>
401	INVALID_API_KEY	API key missing, malformed, expired, or revoked
403	FORBIDDEN	Authenticated, but not allowed (e.g. cross-org)
403	INSUFFICIENT_SCOPE	API key is missing the scope this endpoint requires
404	NOT_FOUND	Generic
404	ASSET_NOT_FOUND	Asset id/tag not in caller's organization
404	REPAIR_NOT_FOUND	Repair id not in caller's organization
404	PHOTO_NOT_FOUND	Photo id does not exist
404	CYCLE_NOT_FOUND	No active audit cycle for the org
409	CONFLICT	Idempotency-key reuse with different body, or business-rule conflict
422	VALIDATION_FAILED	Body / query / path didn't match the schema
429	RATE_LIMITED	Per-key bucket or per-IP login bucket exceeded
500	INTERNAL_ERROR	Server bug. File a ticket with the requestId.

6. Rate limiting

Scope	Default	Configurable via
Per API key, per minute	120	api_keys.rate_limit_per_minute
POST /auth/login per IP, per 15 min	20	LOGIN_RATE_LIMIT_PER_15MIN env

Every response — successful or not — includes:

```
X-RateLimit-Limit: 120
X-RateLimit-Remaining: 47
X-RateLimit-Reset: 1714397340
```

On 429 `RATE_LIMITED`, honour the `Retry-After` header before retrying. Exponential backoff is fine, but never retry sooner than the value provided.

7. Idempotency

Any POST may include Idempotency-Key (16–128 chars, A–Z a–z 0–9 _ -):

Scenario	Result
Key not seen	Handler runs; if 2xx, the body is cached for 24 h
Key seen, same request body hash	Cached response replayed (same status + body)
Key seen, different request body hash	409 CONFLICT
TTL expired (24 h)	Treated as not-seen

Recommended pattern

```
final idem = Uuid().v4(); // generate ONCE per intent
try {
  await api.raiseRepair(assetId, body, idempotencyKey: idem);
} catch (e) {
  if (isNetworkError(e)) {
    // safe to retry – same idem key dedupes server-side
    await api.raiseRepair(assetId, body, idempotencyKey: idem);
  }
}
```

Generate the key when the user **commits the action**, not on every retry. GET and DELETE ignore Idempotency-Key — they're already safe to retry.

8. Pagination

List endpoints currently return up to `limit` items and a `total`. Cursor-based pagination is on the roadmap if needed.

```
{ "items": [...], "total": 47 }
```

`limit` query parameter — default 100, max 500 on most endpoints.

9. Endpoints — Health

GET	/health
-----	---------

Auth	Scope	Idempotency-Key
------	-------	-----------------

Public — no auth	—	—
------------------	---	---

Response 200

```
{
  "ok": true,
  "service": "1xl-asset-tracker-api",
  "env": "production",
  "uptimeSeconds": 142,
  "db": { "ok": true, "latencyMs": 87 },
  "minAppVersion": { "ios": "1.0.0", "android": "1.0.0" },
  "maintenanceMessage": null
}
```

curl

```
curl https://asset.thebizzfly.com/health
```

Notes. db.ok is your readiness probe. minAppVersion drives the in-client force-upgrade screen. maintenanceMessage drives a non-dismissable banner when non-null.

10. Endpoints — Auth

POST /api/v1/auth/login

Auth	Scope	Idempotency-Key
API key only	auth:login	—

Request body

```
{
  "email": "alice@1xl.com",
  "password": "supersecret",
  "deviceId": "iPhone-15-Pro-Alice"
}
```

Field	Type	Required	Notes
email	string	yes	Normalised to lowercase
password	string	yes	1–200 chars
deviceId	string	no	1–128 chars. Stored on the refresh-token row.

Response 200

```
{
  "accessToken": "eyJhbGciOi...",
  "accessTokenExpiresIn": 1800,
  "refreshToken": "rT8K...",
  "refreshTokenExpiresIn": 2592000,
  "user": {
    "id": "...",
    "name": "Alice Admin",
    "email": "alice@1xl.com",
    "role": "admin",
    "departmentId": null,
    "phone": "",
    "avatar": null,
    "isActive": true,
    "organizationId": "..."
  }
}
```

Errors

Status	code	Cause
401	UNAUTHENTICATED	Wrong email/password, or account disabled
403	FORBIDDEN	User belongs to a different org than the API key
422	VALIDATION_FAILED	Bad email format etc.
429	RATE_LIMITED	More than 20 attempts/15 min from this IP

curl

```
curl -X POST https://asset.thebizzfly.com/api/v1/auth/login \
-H "Content-Type: application/json" \
-H "Authorization: Bearer $API_KEY" \
-d '{
  "email": "alice@1xl.com",
  "password": "supersecret"
}'
```

Wrong email and wrong password return identical responses to prevent user-enumeration. Legacy plaintext passwords are bcrypt-hashed on first successful login.

POST	/api/v1/auth/refresh	
Auth	Scope	Idempotency-Key
API key only	auth:refresh	—

Request body

```
{ "refreshToken": "rT8K...", "deviceId": "iPhone-15-Pro-Alice" }
```

Response 200

```
{
  "accessToken": "...",
  "accessTokenExpiresIn": 1800,
  "refreshToken": "...",
  "refreshTokenExpiresIn": 2592000
}
```

Clients **MUST** overwrite the stored refresh token immediately. The previous token is now revoked; presenting it again invalidates every session for the user.

curl

```
curl -X POST https://asset.thebizzfly.com/api/v1/auth/refresh \
-H "Content-Type: application/json" \
-H "Authorization: Bearer $API_KEY" \
-d '{ "refreshToken": ""$REFRESH"" }'
```

POST	/api/v1/auth/logout	
Auth	Scope	Idempotency-Key
API key only	—	—

Request body

```
{ "refreshToken": "rT8K...", "allDevices": false }
```

allDevices=true revokes every active refresh token for the user (sign-out everywhere). Default false.

Response 200

```
{ "ok": true }
```

Idempotent — ok: true even if the token never existed.

curl

```
curl -X POST https://asset.thebizzfly.com/api/v1/auth/logout \
-H "Content-Type: application/json" \
-H "Authorization: Bearer $API_KEY" \
-d '{ "refreshToken": ""$REFRESH"" }'
```

GET**/api/v1/auth/me**

Auth	Scope	Idempotency-Key
User JWT only	auth:read	—

Response 200

```
{
  "user": {
    "id": "...",
    "name": "Alice Admin",
    "email": "alice@1xl.com",
    "role": "admin",
    "departmentId": null,
    "phone": "",
    "avatar": null,
    "isActive": true,
    "organizationId": "..."
  },
  "organization": {
    "id": "...",
    "name": "1XL Infra",
    "shortName": "1xl",
    "logoUrl": "...",
    "currency": "USD",
    "country": "IN",
    "contactEmail": "ops@1xl.com",
    "contactPhone": "...",
    "industry": "Real Estate"
  }
}
```

organization is null for super-admins (they have no org).

curl

```
curl https://asset.thebizzfly.com/api/v1/auth/me \
-H "Authorization: Bearer $ACCESS"
```

11. Endpoints — Assets

Both endpoints below return the **asset envelope** — see section 18 for the full schema. \$TOKEN can be either an API key or a user JWT.

POST /api/v1/assets/lookup-by-qr

Auth	Scope	Idempotency-Key
Either	assets:read	—

Request body

```
{
  "qrPayload": "LAP-1XL-01-001",
  "geoLat": 28.6139,
  "geoLng": 77.2090
}
```

Field	Type	Required	Notes
qrPayload	string	yes	UUID, asset tag, or full /scan/ or /asset/ URL. Tags are uppercased.
geoLat	number	no	Logged for verification context (V2)
geoLng	number	no	

Errors

Status	code	Cause
400	INVALID_QR_PAYLOAD	Couldn't parse the string
404	ASSET_NOT_FOUND	Parsed but no matching asset in this org

curl

```
curl -X POST https://asset.thebizzfly.com/api/v1/assets/lookup-by-qr \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $TOKEN" \
  -d '{ "qrPayload": "LAP-1XL-01-001" }'
```

GET /api/v1/assets/{assetId}

Auth	Scope	Idempotency-Key
Either	assets:read	—

Returns the same envelope shape as /lookup-by-qr.

curl

```
curl https://asset.thebizzfly.com/api/v1/assets/$ASSET_ID \
  -H "Authorization: Bearer $TOKEN"
```

12. Endpoints — Photos

Three-step flow: **(1)** request a presigned URL, **(2)** PUT bytes directly to Supabase Storage, **(3)** finalize. Privacy: clients are responsible for stripping EXIF/GPS before upload.

POST `/api/v1/assets/{assetId}/photos/upload-url`

Auth	Scope	Idempotency-Key
Either	photos:write	Recommended

Request body

```
{
  "filename": "shot.jpg",
  "mimeType": "image/jpeg",
  "sizeBytes": 12345,
  "caption": "Front view"
}
```

Field	Type	Required	Notes
filename	string	yes	Used for the storage path's extension
mimeType	string	yes	image/jpeg image/png image/webp image/heic image/heif
sizeBytes	int	yes	Must be ≤ maxSizeBytes (10 MB default)
caption	string	no	Stored on the photo row; can also be set on finalize

Response 200

```
{
  "photoId": "9c3a...",
  "uploadUrl": "https://xdtqrkjztgjhtahmbjx.supabase.co/storage/v1/object/...",
  "uploadMethod": "PUT",
  "uploadHeaders": {
    "content-type": "image/jpeg",
    "x-upsert": "false"
  },
  "storagePath": "<org>/<asset>/<photoId>.jpg",
  "bucket": "asset-images",
  "expiresInSeconds": 600,
  "maxSizeBytes": 10485760
}
```

Step 2 — direct PUT to Supabase Storage

Send the bytes to `uploadUrl` with the headers from `uploadHeaders`. Do **not** include `Authorization` on this request — the signed URL carries its own token.

POST `/api/v1/assets/{assetId}/photos/{photoId}/finalize`

Auth	Scope	Idempotency-Key
Either	photos:write	Recommended

Request body (optional)

```
{ "caption": "Front view after cleaning" }
```

Response 200

```
{
  "photo": {
    "id": "9c3a...",
    "url": "https://.../public/asset-images/<path>",
    "caption": "Front view after cleaning",
    "mimeType": "image/jpeg",
    "sizeBytes": 12345,
    "createdAt": "2026-04-29T11:30:00Z",
    "finalizedAt": "2026-04-29T11:30:18Z"
  }
}
```

Errors

Status	code	Cause
404	PHOTO_NOT_FOUND	Photo id doesn't exist for this asset
422	VALIDATION_FAILED	Object not found in storage — the PUT didn't actually land

curl — full flow

```
RESP=$(curl -s -X POST \
  https://asset.thebizzfly.com/api/v1/assets/$ASSET_ID/photos/upload-url \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $TOKEN" \
  -d '{"filename": "shot.jpg", "mimeType": "image/jpeg", "sizeBytes": 12345 }')
```

```
PHOTO_ID=$(echo $RESP | jq -r .photoId)
UPLOAD_URL=$(echo $RESP | jq -r .uploadUrl)
```

```
curl -X PUT "$UPLOAD_URL" \
  -H "Content-Type: image/jpeg" \
  -H "x-upsert: false" \
  --data-binary @./shot.jpg
```

```
curl -X POST \
  "https://asset.thebizzfly.com/api/v1/assets/$ASSET_ID/photos/$PHOTO_ID/finalize" \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $TOKEN" \
  -d '{"caption": "Front view after cleaning" }'
```

13. Endpoints — Maintenance

GET	/api/v1/assets/{assetId}/maintenance	
Auth	Scope	Idempotency-Key
Either	maintenance:read	—

Response 200

```
{
  "items": [
    {
      "id": "...",
      "assetId": "...",
      "scheduledDate": "2026-04-15T10:00:00Z",
      "completedDate": "2026-04-15T10:42:00Z",
      "technicianId": "...",
      "status": "completed",
      "type": "preventive",
      "cost": 0,
      "notes": "[task:cleaning] Cleaned vents and screen",
      "checklist": ["Vents cleaned", "Screen wiped"],
      "organizationId": "...",
      "createdAt": "..."
    }
  ],
  "total": 1
}
```

curl

```
curl https://asset.thebizzfly.com/api/v1/assets/$ASSET_ID/maintenance \
-H "Authorization: Bearer $TOKEN"
```

GET	/api/v1/maintenance/task-types	
Auth	Scope	Idempotency-Key
Either	maintenance:read	—

Response 200

```
{
  "items": [
    { "id": "preventive_inspection", "label": "Preventive Inspection", "defaultType": "preventive" },
    { "id": "cleaning", "label": "Cleaning", "defaultType": "preventive" },
    { "id": "firmware_update", "label": "Firmware/Software Update", "defaultType": "preventive" },
    { "id": "lubrication", "label": "Lubrication", "defaultType": "preventive" },
    { "id": "calibration", "label": "Calibration", "defaultType": "preventive" },
    { "id": "replacement", "label": "Part Replacement", "defaultType": "corrective" },
    { "id": "corrective_other", "label": "Corrective – Other", "defaultType": "corrective" }
  ]
}
```

curl

```
curl https://asset.thebizzfly.com/api/v1/maintenance/task-types \
-H "Authorization: Bearer $TOKEN"
```

POST /api/v1/assets/{assetId}/maintenance

Auth	Scope	Idempotency-Key
Either	maintenance:write	Recommended

Request body

```
{
  "taskId": "cleaning",
  "type": "preventive",
  "scheduledDate": "2026-04-29T11:00:00Z",
  "completedDate": "2026-04-29T11:30:00Z",
  "technicianId": null,
  "cost": 0,
  "notes": "Cleaned vents and screen",
  "checklist": ["Vents cleaned", "Screen wiped"],
  "status": "completed"
}
```

Field	Type	Required	Default	Notes
taskId	string	yes	—	Echoed into notes as [task:<id>]
type	enum	yes	—	preventive corrective
scheduledDate	datetime	no	now	
completedDate	datetime	no	now (if completed)	
technicianId	UUID	no	the caller	Must belong to caller's org
cost	number	no	0	
notes	string	no	""	Max 2000 chars
checklist	string[]	no	[]	Max 50 × 200 chars
status	enum	no	completed	scheduled in_progress completed overdue cancelled

curl

```
curl -X POST \
https://asset.thebizzfly.com/api/v1/assets/$ASSET_ID/maintenance \
-H "Content-Type: application/json" \
-H "Authorization: Bearer $TOKEN" \
-H "Idempotency-Key: $(uuidgen)" \
-d '{
  "taskId": "cleaning",
  "type": "preventive",
  "notes": "Cleaned vents and screen",
  "checklist": ["Vents cleaned", "Screen wiped"]
}'
```

14. Endpoints — Repairs

GET `/api/v1/assets/{assetId}/repairs`

Auth	Scope	Idempotency-Key
Either	repairs:read	—

Response 200

```
{
  "items": [
    {
      "id": "...",
      "assetId": "...",
      "vendorId": null,
      "technicianId": null,
      "issue": "Battery does not charge past 80%",
      "status": "in_progress",
      "priority": "medium",
      "cost": 0,
      "partsUsed": "",
      "laborHours": 0,
      "completionDate": null,
      "notes": "Reproduced 3 times today",
      "organizationId": "...",
      "createdAt": "..."
    }
  ],
  "total": 1
}
```

curl

```
curl https://asset.thebizzfly.com/api/v1/assets/$ASSET_ID/repairs \
-H "Authorization: Bearer $TOKEN"
```

GET `/api/v1/repairs/{repairId}`

Auth	Scope	Idempotency-Key
Either	repairs:read	—

Response 200

```
{
  "repair": { /* same shape as above */ },
  "vendor": { "id": "...", "name": "TechFix Inc",
    "contactPerson": "...", "phone": "..." },
  "updates": [
    { "id": "...", "statusFrom": null, "statusTo": "pending",
      "note": "Repair raised via API", ... },
    { "id": "...", "statusFrom": "pending", "statusTo": "in_progress",
      "note": "Picked up by IT, diagnosing", ... }
  ]
}
```

curl

```
curl https://asset.thebizzfly.com/api/v1/repairs/$REPAIR_ID \
-H "Authorization: Bearer $TOKEN"
```

POST /api/v1/assets/{assetId}/repairs

Auth	Scope	Idempotency-Key
Either	repairs:write	Recommended

Request body

```
{
  "issue": "Battery does not charge past 80%",
  "priority": "medium",
  "vendorId": null,
  "technicianId": null,
  "partsUsed": "",
  "notes": "Reproduced 3 times today"
}
```

Field	Type	Required	Notes
issue	string	yes	3–2000 chars
priority	enum	no	low medium (default) high critical
vendorId	UUID	no	If set, ticket starts in 'assigned'
technicianId	UUID	no	Same
partsUsed	string	no	Max 500 chars
notes	string	no	Max 2000 chars

curl

```
curl -X POST https://asset.thebizzfly.com/api/v1/assets/$ASSET_ID/repairs \
-H "Content-Type: application/json" \
-H "Authorization: Bearer $TOKEN" \
-H "Idempotency-Key: $(uuidgen)" \
-d '{
  "issue": "Battery does not charge past 80%",
  "priority": "medium",
  "notes": "Reproduced 3 times today"
}'
```

POST /api/v1/repairs/{repairId}/updates

Auth	Scope	Idempotency-Key
Either	repairs:write	Recommended

Request body

```
{
  "statusTo": "in_progress",
  "note": "Picked up by IT, diagnosing",
  "partsUsed": "battery cell",
  "laborHours": 0.5,
  "cost": 75
}
```

Field	Type	Required	Notes
statusTo	enum	no	pending assigned in_progress completed cancelled. If omitted, status is unchanged.
note	string	yes	1–2000 chars
partsUsed	string	no	Replaces existing value if set
laborHours	number	no	Replaces existing value if set
cost	number	no	Replaces existing value if set

If statusTo === "completed", server stamps completion_date = now().

curl

```
curl -X POST https://asset.thebizzfly.com/api/v1/repairs/$REPAIR_ID/updates \
-H "Content-Type: application/json" \
-H "Authorization: Bearer $TOKEN" \
-H "Idempotency-Key: $(uuidgen)" \
-d '{
  "statusTo": "in_progress",
  "note": "Picked up by IT, diagnosing"
}'
```

15. Endpoints — Recovery

POST	/api/v1/assets/{assetId}/recovery	
Auth	Scope	Idempotency-Key
Either	recovery:write	Recommended

Files a loss / damage / theft / claim / write-off incident. Optionally flips the asset to dead **atomically** — if the asset update fails, the recovery row is rolled back.

Request body

```
{
  "incidentType": "stolen",
  "severity": "high",
  "description": "Reported missing from desk 4B",
  "estimatedLoss": 1200,
  "incidentDate": "2026-04-29T09:00:00Z",
  "markAssetDead": true
}
```

Field	Type	Required	Notes
incidentType	enum	yes	lost damaged stolen insurance_claim write_off
severity	enum	no	low medium (default) high critical
description	string	yes	3–2000 chars
estimatedLoss	number	no	Default 0
incidentDate	datetime	no	Default now
markAssetDead	boolean	no	Default false. When true, asset.status becomes 'dead'.

Response 201

```
{
  "recovery": {
    "id": "...",
    "incidentType": "stolen",
    "status": "reported",
    ...
  },
  "asset": {
    "id": "...",
    "status": "dead",
    ...
  }
}
```

asset is null if markAssetDead was false.

Errors

Status	code	Cause
409	CONFLICT	Asset is already 'dead' or 'disposed'

curl

```
curl -X POST https://asset.thebizzfly.com/api/v1/assets/$ASSET_ID/recovery \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $TOKEN" \
  -H "Idempotency-Key: $(uuidgen)" \
  -d '{
    "incidentType": "stolen",
    "severity": "high",
    "description": "Reported missing from desk 4B",
    "estimatedLoss": 1200,
    "markAssetDead": true
  }'
```

16. Endpoints — Audit

Both endpoints upsert one row per (cycle, asset). The active cycle is found automatically; pass `cycleId` only to target a specific one.

POST `/api/v1/assets/{assetId}/audit/verify`

Auth	Scope	Idempotency-Key
Either	audit:write	Recommended

Request body

```
{
  "cycleId": null,
  "actualLocationId": "...",
  "actualAssigneeId": "...",
  "notes": "Verified in person",
  "geoLat": 28.6139,
  "geoLng": 77.2090
}
```

Response 201

```
{
  "verification": {
    "id": "...",
    "cycleId": "...",
    "assetId": "...",
    "verifierId": "...",
    "result": "verified",
    "expectedLocationId": "...",
    "actualLocationId": "...",
    "expectedAssigneeId": "...",
    "actualAssigneeId": "...",
    "flagReason": null,
    "notes": "Verified in person",
    "geoLat": 28.6139,
    "geoLng": 77.209,
    "createdAt": "..."
  }
}
```

Errors

Status	code	Cause
404	CYCLE_NOT_FOUND	No active audit cycle for the org

curl

```
curl -X POST \
  https://asset.thebizzfly.com/api/v1/assets/$ASSET_ID/audit/verify \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $TOKEN" \
  -H "Idempotency-Key: $(uuidgen)" \
  -d '{"notes": "Verified in person"}'
```

POST	/api/v1/assets/{assetId}/audit/flag	
Auth	Scope	Idempotency-Key
Either	audit:write	Recommended

Request body

```
{
  "cycleId": null,
  "flagReason": "wrong_location",
  "actualLocationId": "...",
  "actualAssigneeId": null,
  "notes": "Found in Conference Room B; expected Floor 4 storage",
  "geoLat": 28.6139,
  "geoLng": 77.2090
}
```

Field	Type	Required	Notes
cycleId	UUID	no	Default = active cycle
flagReason	enum	yes	wrong_location wrong_assignee damaged missing other
actualLocationId	UUID	no	What you actually saw — null if missing
actualAssigneeId	UUID	no	Same
notes	string	yes	3–1000 chars
geoLat / geoLng	number	no	Coordinates of the flag

curl

```
curl -X POST \
  https://asset.thebizzfly.com/api/v1/assets/$ASSET_ID/audit/flag \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer $TOKEN" \
  -H "Idempotency-Key: $(uuidgen)" \
  -d '{
    "flagReason": "wrong_location",
    "notes": "Found in Conference Room B; expected Floor 4 storage"
  }'
```

17. Endpoints — Reference data

Picker sources for client dropdowns when raising repairs, flagging audits, etc. Both accept `q` (substring search) and `limit` (default 100, max 500).

GET `/api/v1/reference/users`

Auth	Scope	Idempotency-Key
Either	reference:read	—

Response 200

```
{
  "items": [
    {
      "id": "...",
      "name": "Bob Technician",
      "email": "bob@1xl.com",
      "role": "technician",
      "departmentId": null,
      "phone": "...",
      "avatar": null
    }
  ],
  "total": 1
}
```

curl

```
curl "https://asset.thebizzfly.com/api/v1/reference/users?q=bob&limit=10" \
-H "Authorization: Bearer $TOKEN"
```

GET `/api/v1/reference/locations`

Auth	Scope	Idempotency-Key
Either	reference:read	—

Response 200

```
{
  "items": [
    {
      "id": "...",
      "name": "Head Office",
      "address": "...",
      "city": "Delhi",
      "state": "DL",
      "country": "IN",
      "floorNo": "4"
    }
  ],
  "total": 1
}
```

curl

```
curl "https://asset.thebizzfly.com/api/v1/reference/locations?limit=50" \  
-H "Authorization: Bearer $TOKEN"
```

18. Schemas

Asset envelope

The single source of truth for the client asset screen. Returned by `/lookup-by-qr` and `GET /assets/{id}`.

```
{
  "asset": {
    "id": "uuid",
    "assetTag": "LAP-1XL-01-001",
    "name": "Dell XPS 13 – Alice",
    "type": "it_equipment",
    "category": "Laptop",
    "brand": "Dell",
    "model": "XPS 13",
    "serialNumber": "SN-12345",
    "status": "allocated",
    "description": "...",
    "purchaseDate": "2024-09-01",
    "purchaseCost": 1200,
    "currency": "USD",
    "warrantyStart": "2024-09-01",
    "warrantyEnd": "2027-09-01",
    "imageUrl": "https://.../primary.jpg",
    "imageUrls": ["https://.../1.jpg", "..."],
    "processor": "Intel i7-1360P",
    "ram": "16 GB",
    "storage": "512 GB SSD",
    "assetUse": "personal",
    "organizationId": "uuid",
    "createdAt": "...",
    "updatedAt": "..."
  },
  "location": { ... } | null,
  "department": { ... } | null,
  "vendor": { ... } | null,
  "currentAllocation": {
    "id": "uuid", "status": "active",
    "startDate": "2024-09-15", "endDate": null,
    "allocationType": "new_employee",
    "employeeId": "uuid", "departmentId": "uuid"
  } | null,
  "currentAssignee": {
    "id": "uuid", "name": "Alice Admin",
    "email": "alice@1xl.com", "phone": "...", "role": "admin"
  } | null,
  "auditContext": {
    "cycleId": "uuid",
    "cycleName": "Q2 2026",
    "cycleStartsAt": "2026-04-01T00:00:00Z",
    "cycleEndsAt": null,
    "expectedLocationId": "uuid",
    "expectedAssigneeId": "uuid",
    "currentVerification": {
      "id": "uuid", "result": "verified", "createdAt": "..."
    } | null
  } | null,
  "permittedActions": [
    "add_photo", "log_maintenance", "raise_repair",
    "update_repair", "mark_recovery", "verify_audit"
  ]
}
```

auditContext is null when no audit cycle is active. currentVerification is null when this asset hasn't been touched in the active cycle yet.

User

```
{
  "id": "uuid",
  "name": "Alice Admin",
  "email": "alice@1xl.com",
  "role": "admin",
  "departmentId": "uuid" | null,
  "phone": "...",
  "avatar": "https://..." | null,
  "isActive": true,
  "organizationId": "uuid" | null
}
```

Organization

```
{
  "id": "uuid",
  "name": "1XL Infra",
  "shortName": "1xl",
  "logoUrl": "https://..." | null,
  "currency": "USD",
  "country": "IN" | null,
  "contactEmail": "...",
  "contactPhone": "...",
  "industry": "Real Estate"
}
```

19. Scope catalogue

Every endpoint requires the API key to carry the matching scope. Defined in `server/src/lib/scopes.ts`. The web admin page's **Default scopes** button selects the standard bundle.

Scope	Endpoints
auth:login	POST /auth/login
auth:refresh	POST /auth/refresh
auth:read	GET /auth/me
assets:read	POST /assets/lookup-by-qr, GET /assets/:id
assets:write	(reserved)
photos:write	POST /assets/:id/photos/upload-url, /finalize
maintenance:read	GET /assets/:id/maintenance, GET /maintenance/task-types
maintenance:write	POST /assets/:id/maintenance
repairs:read	GET /assets/:id/repairs, GET /repairs/:id
repairs:write	POST /assets/:id/repairs, POST /repairs/:id/updates
recovery:write	POST /assets/:id/recovery
audit:read	(reserved — no read endpoint yet)
audit:write	POST /assets/:id/audit/verify, /flag
reference:read	GET /reference/users, /locations

Wildcards

Form	Effect
<resource>:*	All actions on a resource (e.g. assets:*, repairs:*)
*	All scopes (god-mode key — use sparingly)

20. Permitted-actions matrix

The `permittedActions` array in every asset envelope is computed server-side per (user, asset). Clients show action tiles based on it — never roll your own client-side check.

Action	Admin	Manager	Technician	Vendor	Auditor	Employee	Staff
add_photo	✓	✓	✓	—	✓	✓	✓
log_maintenance	✓	✓	✓	—	—	—	—
raise_repair	✓	✓	✓	—	—	✓	✓
update_repair	✓	✓	✓	✓	—	—	—
mark_recovery	✓	✓	—	—	—	—	—
verify_audit	✓	✓	—	—	✓	—	—

When `asset.status` is retired, disposed, or dead, the only permitted action is `add_photo` (regardless of role). Integrations using an API key without a user JWT are treated as admin-equivalent — their authority comes from explicit scope grants on the key.

21. Asset status enum

Canonical seven values. Clients should adopt these exactly.

Value	Display	Means
available	Available	In inventory, not assigned
allocated	Allocated	Assigned to a person
in_use	In Use (Shared)	Common-use asset (printer, conference TV)
under_maintenance	Under Maintenance	Temporarily out of service
retired	Retired	End of life, not in active use
disposed	Disposed	Sold or scrapped
dead	Dead	Lost / stolen / written off

22. Versioning policy

Rule	Detail
/api/v1/* is additive-only	Adding optional fields, new endpoints, new enum values is allowed.
Breaking changes get /api/v2/*	v1 stays alive in parallel for at least one client release cycle.
Stable error codes	error.code strings never change meaning across versions.
Deprecation signals	Sunset endpoints carry Deprecation: true and Sunset: <date> response headers months ahead of

23. Changelog & support

Changelog

Version	Date	Notes
1.0	2026-04-29	Initial release. Single Authorization: Bearer scheme, org-prefixed API keys, auth (login/refresh/logout/m

Where to file issues

Include the requestId from the failing response. Server logs are indexed on this field — without it, debugging is much slower.

Quick reference card

BASE HEADERS		https://asset.thebizzfly.com (or http://localhost:4000) Authorization: Bearer <token> (token = API key OR user JWT) Idempotency-Key: <uuid> (recommended on POSTs) X-Request-Id: <id> (recommended on every call)
AUTH	POST	/api/v1/auth/login
	POST	/api/v1/auth/refresh
	POST	/api/v1/auth/logout
	GET	/api/v1/auth/me
ASSETS	POST	/api/v1/assets/lookup-by-qr
	GET	/api/v1/assets/:id
PHOTOS	POST	/api/v1/assets/:id/photos/upload-url
	POST	/api/v1/assets/:id/photos/:photoId/finalize
MAINT	GET	/api/v1/assets/:id/maintenance
	GET	/api/v1/maintenance/task-types
	POST	/api/v1/assets/:id/maintenance
REPAIRS	GET	/api/v1/assets/:id/repairs
	GET	/api/v1/repairs/:id
	POST	/api/v1/assets/:id/repairs
	POST	/api/v1/repairs/:id/updates
RECOVERY	POST	/api/v1/assets/:id/recovery
AUDIT	POST	/api/v1/assets/:id/audit/verify
	POST	/api/v1/assets/:id/audit/flag
REFERENCE	GET	/api/v1/reference/users
	GET	/api/v1/reference/locations
HEALTH	GET	/health